

UNIDAD 2 — LA VPS: APROVISIONAR, ENTRAR Y CERRAR

Clase 2 · La VPS: aprovisionar, entrar y cerrar

Ejercicios de teoría

Programación 3 — Tecnicatura Universitaria en Programación — UTN FRM

Modalidad	En grupos de dos o tres. Se responde con el apunte de la clase a mano.
Tiempo sugerido	50 a 60 minutos.
Puntaje total	100 puntos. Partes A (20), B (10), C (30), D (30) y E (10).
Qué se evalúa	Que puedan nombrar el concepto que explica cada síntoma, no que recuerden comandos de memoria.

Antes de arrancar. Todo lo que se pregunta acá está en el capítulo 2 del apunte. No es una prueba de memoria: es una prueba de lectura con criterio. Cuando dudes, buscá la sección; encontrarla también es parte del ejercicio.

Integrantes:

Parte A — Verdadero o falso, con justificación

20 puntos (2 por ítem)

Indicá si cada afirmación es verdadera o falsa. **La justificación es obligatoria:** una respuesta sin justificar no suma puntaje. Una línea alcanza.

- A1.** Si el VPS queda comprometido, el proveedor puede auditar lo que pasó adentro del sistema operativo y ayudar a resolverlo.
-
-
- A2.** En la autenticación por clave pública, la clave privada viaja cifrada hasta el servidor para que este pueda compararla con la pública.
-
-
- A3.** La directiva PermitRootLogin prohibit-password impide entrar al servidor como root.
-
-
- A4.** Un servicio que escucha en 127.0.0.1 es inalcanzable desde internet aunque el firewall esté apagado y el puerto abierto.
-
-

- A5.** Si sudo `ufw status` informa que el puerto 5432 está bloqueado, entonces el puerto 5432 está efectivamente cerrado.
-
-
- A6.** Un servidor web necesita un puerto distinto por cada conexión simultánea que atiende.
-
-
- A7.** Si toda la aplicación funciona por HTTPS, el puerto 80 se puede cerrar sin consecuencias.
-
-
- A8.** Que Docker se saltee `ufw` es un error conocido de Ubuntu que se corrige actualizando el sistema.
-
-
- A9.** En un sistema Unix, poner un proceso a escuchar en el puerto 3000 requiere privilegios de administrador.
-
-
- A10.** Con fail2ban instalado, el servidor queda protegido contra un atacante que quiera entrar por SSH.
-
-

Parte B — Opción múltiple

10 puntos (1 por ítem)

Marcá **una sola** opción por ítem.

- B1.** ¿Qué hace que el aislamiento entre dos VPS alojados en el mismo servidor físico sea real y no una promesa comercial?
- a) Un contrato de nivel de servicio con el proveedor
 - b) Que el procesador hace cumplir por hardware la separación de los espacios de memoria
 - c) Que cada VPS tiene su propia dirección IP pública
 - d) Que el hipervisor cifra el disco de cada cliente
- B2.** El fenómeno del «vecino ruidoso» —el servidor se pone lento sin que nada haya cambiado de tu lado— se explica por...
- a) ...una falla del hipervisor
 - b) ...el sobreaprovisionamiento: el proveedor vende más núcleos virtuales que núcleos reales
 - c) ...la caché negativa del DNS
 - d) ...que el disco virtual es una imagen y no un disco real

- B3.** En una conexión SSH, ¿qué se autentica **primero**?
- a) El cliente ante el servidor, con su clave privada
 - b) El servidor ante el cliente, presentando su clave de anfitrión
 - c) Ambos simultáneamente, en la capa de conexión
 - d) Ninguno: SSH solo cifra, la autenticación la hace el sistema operativo
- B4.** El modelo de confianza en el primer uso (TOFU) que usa SSH significa que...
- a) ...la conexión es insegura hasta que se instala un certificado
 - b) ...es vulnerable exactamente una vez —la primera— y a partir de ahí detecta cualquier suplantación
 - c) ...la clave del anfitrión se verifica contra una autoridad certificadora
 - d) ...hay que aceptar la huella cada vez que uno se conecta
- B5.** Un paquete que llega desde internet al puerto publicado de un contenedor **no pasa por INPUT** porque...
- a) ...Docker desactiva la cadena INPUT al instalarse
 - b) ...tras el DNAT en PREROUTING el destino ya es la IP del contenedor, y la decisión de enrutamiento lo manda por FORWARD
 - c) ...ufw lo excluye explícitamente de sus reglas
 - d) ...los contenedores usan UDP en lugar de TCP
- B6.** Los puertos del rango 49152–65535 se llaman dinámicos o efímeros porque...
- a) ...expiran después de un tiempo de inactividad
 - b) ...no los asigna nadie: los toma el sistema operativo, típicamente como puerto de origen
 - c) ...solo pueden usarse con privilegios de administrador
 - d) ...la IANA los reserva para uso experimental
- B7.** En `ss -tlnp`, la bandera `-l` pide...
- a) ...que se muestren los nombres de los servicios en lugar de los números
 - b) ...únicamente los sockets en estado LISTEN, es decir los que esperan conexiones nuevas
 - c) ...los sockets locales del sistema de archivos
 - d) ...un listado largo con más columnas
- B8.** ¿Para qué sirve la bandera `-Pn` de `nmap`?
- a) Para escanear también puertos UDP
 - b) Para que no intente primero un ping de descubrimiento y escanee directamente
 - c) Para omitir los puertos privilegiados
 - d) Para que el escaneo no quede registrado en los logs del destino
- B9.** Para un PostgreSQL que solo tiene que ser alcanzable por la API del mismo proyecto, la estrategia **preferida** del capítulo es...
- a) No declarar ningún mapeo de puertos: no publicarlo en absoluto
 - b) Publicarlo con `-p 5432:5432` y bloquearlo con `ufw`
 - c) Publicarlo y escribir reglas en la cadena DOCKER-USER
 - d) Publicarlo con una contraseña larga

- B10.** La razón principal por la que el capítulo elige Ed25519 en lugar de RSA de 4096 bits es que...
- a) RSA ya fue quebrado criptográficamente
 - b) Ed25519 tiene un solo tamaño de clave y por lo tanto muchas menos formas de configurarlo mal
 - c) Ed25519 es el único que soporta OpenSSH
 - d) RSA no funciona con autenticación por desafío

Parte C — Desarrollo conceptual

30 puntos (3 por ítem)

Respondé con precisión y brevedad. Se evalúa que uses el vocabulario técnico del capítulo, no la extensión de la respuesta.

- C1.** Enunciá las tres propiedades que Popek y Goldberg exigieron en 1974 para llamar «virtualizador» a un sistema, y explicá por qué la virtualización tardó treinta años en llegar a los servidores comunes.

- C2.** Diferenciá hipervisor de **tipo 1** y de **tipo 2**, dando un ejemplo de cada uno, e indicá cuál usa el VPS del práctico.

- C3.** De la arquitectura del VPS se desprenden tres consecuencias prácticas. Enunciá las tres y dá un efecto observable de cada una.

- C4.** El módulo podría haber usado un PaaS y el despliegue tendría menos pasos. Explicá por qué se eligió un VPS, en términos del eje que ordena la tabla de modalidades.

- C5.** Nombrá las tres capas del protocolo SSH, en orden, y decí qué ocurre en cada una.
-
-
-
-
- C6.** Explicá el mecanismo de la autenticación por clave pública y justificá por qué un servidor comprometido no compromete el acceso.
-
-
-
-
- C7.** «Un socket se identifica por una tupla, no por un puerto.» Explicá la afirmación y usala para justificar cómo un servidor con un único puerto 443 atiende diez mil conexiones simultáneas.
-
-
-
-
- C8.** Enumerá los cinco puntos de enganche de netfilter y explicá qué papel cumple la **decisión de enrutamiento**.
-
-
-
-
- C9.** Enunciá los tres principios de Saltzer y Schroeder que el capítulo destaca y dá **una aplicación concreta de cada uno** tomada de este mismo capítulo.
-
-
-
-
- C10.** ¿Qué es la **defensa en profundidad**? Nombrá las cuatro capas que tiene este servidor y explicá qué supone cada una respecto de las demás.
-
-
-
-

Parte D — Casos de diagnóstico

30 puntos (5 por caso)

Para cada caso indicá: **(a)** el diagnóstico, **(b)** el comando o la evidencia con la que lo confirmarías y **(c)** la corrección. Nombrá el concepto del capítulo que explica el síntoma.

- D1.** Un grupo levantó PostgreSQL en un contenedor con `-p 5432:5432`, corrió `sudo ufw deny 5432` y verificó con `ufw status` que figura bloqueado. Un compañero escanea el servidor desde su casa y el 5432 le aparece **abierto**. **Seguí el recorrido del paquete** y explicá por qué las dos observaciones son correctas.

- D2.** Un grupo conectado por SSH corre `sudo ufw enable` y la terminal se congela. No pueden volver a entrar por más que reintenten.

- D3.** De los cuatro integrantes, tres entran al servidor sin problema y el cuarto recibe `Permission denied (publickey)`. Enumerá las causas posibles según el capítulo y cómo distinguirlas.

- D4.** Al conectarse el lunes, un integrante recibe una advertencia grande de que **la clave del anfitrión cambió** y que podría estar ocurriendo un ataque. Un compañero le dice que borre la línea de `known_hosts` y siga. ¿Está bien ese consejo?

- D5.** Un estudiante dice: «esto es una calculadora de la facultad, no tiene datos de nadie. ¿Quién va a querer hackearla?» Desarmá el razonamiento con los datos del capítulo.

- D6.** El grupo configuró `easypanel.tudominio.me` en Settings » Domain, esperó, y el certificado no se emite: el navegador no abre el panel por HTTPS. Indicá las dos causas que contempla el capítulo y cómo distinguirlas.

Parte E — Lectura de salidas reales

10 puntos

Leer la salida de una herramienta **es** leer el sistema. Respondé mirando el bloque de cada ítem.

E1.

```
# ss -tlnp
State  Recv-Q  Send-Q  Local Address:Port  Process
LISTEN  0        4096    0.0.0.0:22          users:(("sshd",pid=812))
LISTEN  0        4096    0.0.0.0:80          users:(("traefik",pid=1544))
LISTEN  0        4096    0.0.0.0:443         users:(("traefik",pid=1544))
LISTEN  0        4096    0.0.0.0:3000        users:(("docker-proxy",pid=1602))
LISTEN  0        244     127.0.0.1:5432      users:(("postgres",pid=1489))
```

(4 puntos) Indicá: (i) cuáles de estos servicios son alcanzables desde internet y cuáles no, y por qué; (ii) cuáles necesita ver el mundo entero; (iii) a qué rango de la RFC 6335 pertenecen el 22, el 3000 y el 5432; (iv) qué te dice el proceso responsable del puerto 3000 sobre si ufw lo protege.

E2.

```
# sudo ufw status verbose
Estado: activo
Perfil predeterminado: deny (incoming), allow (outgoing)
Hasta      Acción      Desde
22/tcp     ALLOW IN    Anywhere
80/tcp     ALLOW IN    Anywhere
443/tcp    ALLOW IN    Anywhere

--- desde la notebook de un compañero, en otra red ---
$ nmap -Pn tudominio.me
PORT      STATE  SERVICE
22/tcp    open   ssh
80/tcp    open   http
443/tcp   open   https
3000/tcp  open   ppp
```

(3 puntos) Las dos salidas se contradicen. ¿Cuál de las dos describe el estado real del servidor y por qué? ¿Cuál es la conclusión operativa?

E3.

```
root@vps:~# uptime
21:14:03 up 3 hours, 12 min, 1 user

root@vps:~# grep -c "Failed password" /var/log/auth.log
1847
```

(3 puntos) El servidor se creó hoy a la tarde y su dirección no se le dio a nadie. Calculá la tasa aproximada por hora, explicá qué demuestra el número y decí qué medida del capítulo vuelve ese número irrelevante.

Cierre — una para pensar (sin puntaje)

El capítulo señala una forma de error que se repite en toda la ingeniería: **una herramienta te informó sobre sí misma y vos lo leíste como información sobre el sistema**. `ufw status` no dice «el 5432 está cerrado»; dice «yo tengo una regla que lo cierra».

Discutan en el grupo: ¿qué otras herramientas que usan todas las semanas les hablan de sí mismas y ustedes las leen como si hablaran del mundo? Piensen en el panel DNS de la Clase 1, en «los tests pasan», en «el build compiló», en «el deploy dice Success». En cada uno de esos casos, ¿cuál sería la verificación equivalente a correr `nmap` desde afuera?

.....

.....

.....

.....

.....